

# Controls and compliance checklist

To complete the controls assessment checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each control, including the type and purpose, refer to the [control categories](#) document.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently have this control in place?*

## Controls assessment checklist

| Yes | No | Control                 | Explanation                                                                                                                      |
|-----|----|-------------------------|----------------------------------------------------------------------------------------------------------------------------------|
|     | ×  | Least Privilege         | Currently, all employees have access to customer data; privileges need to be limited to reduce the risk of a breach.             |
|     | ×  | Disaster recovery plans | There are no disaster recovery plans in place. These need to be implemented to ensure business continuity.                       |
|     | ×  | Password policies       | Employee password requirements are minimal, which could allow a threat actor to more easily access secure data and other assets. |
|     | ×  | Separation of duties    | Needs to be implemented to reduce the possibility of fraud and limit access to critical data.                                    |
| ×   |    | Firewall                | The existing firewall blocks traffic based on an appropriately defined set of security rules.                                    |

|   |                                                                     |                                                                                                                               |
|---|---------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------|
| × | Intrusion detection system (IDS)                                    | The IT department needs an IDS in place to help identify possible intrusions by threat actors.                                |
| × | Backups                                                             | The IT department needs to have backups of critical data to ensure business continuity in the event of a breach.              |
| × | Antivirus software                                                  | Antivirus software is installed and monitored regularly by the IT department.                                                 |
| × | Manual monitoring, maintenance, and intervention for legacy systems | Legacy systems are monitored, but there is no regular schedule in place for this task, and intervention policies are unclear. |
| × | Encryption                                                          | Encryption is not currently used; implementing it would provide greater confidentiality of sensitive information.             |
| × | Password management system                                          | There is no password management system currently in place to enforce minimum requirements.                                    |
| × | Locks (offices, storefront, warehouse)                              | The store's physical location has sufficient locks.                                                                           |
| × | Closed-circuit television (CCTV) surveillance                       | The store's physical location has a functioning CCTV.                                                                         |
| × | Fire detection/prevention (fire alarm, sprinkler system, etc.)      | The store's physical location has a fire detection/prevention system.                                                         |

---

To complete the compliance checklist, refer to the information provided in the [scope, goals, and risk assessment report](#). For more details about each compliance regulation, review the [controls, frameworks, and compliance](#) reading.

Then, select “yes” or “no” to answer the question: *Does Botium Toys currently adhere to this compliance best practice?*

## Compliance checklist

### Payment Card Industry Data Security Standard (PCI DSS)

| Yes | No | Best practice                                                                                                | Explanation                                                                                                        |
|-----|----|--------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------|
|     | ×  | Only authorized users have access to customers’ credit card information.                                     | Currently, all employees have access to the company’s internal data, including customers’ credit card information. |
|     | ×  | Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment. | Credit card information is not stored in a secure environment.                                                     |
|     | ×  | Implement data encryption procedures to better secure credit card transaction touchpoints and data.          | Credit card information is not encrypted and secure.                                                               |
|     | ×  | Adopt secure password management policies.                                                                   | Password policies are nominal, and no secure password management system is in place.                               |

### General Data Protection Regulation (GDPR)

| Yes | No | Best practice                                 | Explanation                                                 |
|-----|----|-----------------------------------------------|-------------------------------------------------------------|
|     | ×  | E.U. customers’ data is kept private/secured. | The company does not currently use encryption to ensure the |

|   |                                                                                                                   |                                                                                                     |
|---|-------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|
|   |                                                                                                                   | confidentiality of customers' financial information.                                                |
| × | There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach. | There is a plan to notify E.U. customers within 72 hours of a data breach.                          |
|   | ×                                                                                                                 | Ensure data is properly classified and inventoried.                                                 |
|   |                                                                                                                   | Current assets have been inventoried but not classified.                                            |
| × | Enforce privacy policies, procedures, and processes to properly document and maintain data.                       | Privacy policies, procedures, and processes have been developed and enforced among IT team members. |

#### System and Organizations Controls (SOC type 1, SOC type 2)

| Yes | No | Best practice                                                                              | Explanation                                                                                                                             |
|-----|----|--------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------|
|     | ×  | User access policies are established.                                                      | Controls of Least Privilege and separation of duties are not currently in place, giving all employees access to internally stored data. |
|     | ×  | Sensitive data (PII/SPII) is confidential/private.                                         | Encryption is not currently used to ensure the confidentiality of sensitive data (PII/SPII).                                            |
| ×   |    | Data integrity ensures the data is consistent, complete, accurate, and has been validated. | Data integrity is in place.                                                                                                             |
|     | ×  | Data is available to individuals authorized to access it.                                  | Currently in place, giving all employees access to internally stored data.                                                              |

**Recommendations (optional):** Multiple controls need to be implemented to improve Botium Toys' security posture and better ensure the confidentiality of sensitive information. The IT department should prioritize implementing Least Privilege, disaster recovery plans, robust password policies, separation of duties, an IDS, ongoing legacy system management, encryption, and a centralized password management system.

To address gaps in compliance, Botium Toys must properly classify all assets to identify additional controls that may need to be implemented to improve their security posture and protect sensitive data.